

LLM-Driven RAG Compliance Pipeline for Automated Privacy Auditing: Capstone Project Proposal and Literature Review

Aaron Joseph Jean
Student ID: 25233118
Department of Computer Science and Engineering
Email: aaronjjean@gmail.com

June 15, 2026

Abstract

Modern privacy regulations, such as the General Data Protection Regulation (GDPR) and the California Consumer Privacy Act (CCPA), mandate strict rules regarding user consent, data collection, and tracking disclosure. However, verifying whether a website’s actual technical behavior matches the claims in its written privacy and cookie policies remains a manual, error-prone, and unscalable task. This project proposes a hybrid, automated auditing framework that uses Retrieval-Augmented Generation (RAG) and Large Language Models (LLMs) to verify compliance. The framework ingests static legal regulations into a local vector database using a legal-specific embedding model. At runtime, it collects dynamic behavioral telemetry (HTTP Archive (HAR) logs and DOM events) from target websites using headless browser automation and extracts the site’s privacy policies. An LLM-based compliance scorer then cross-references the behavioral evidence and policy claims against retrieved legal articles to score compliance across multiple dimensions, generate citations, and compile actionable recommendations. A literature review of ten foundational papers demonstrates the research gap: existing systems audit policies or traffic in isolation, or rely on static program analysis of mobile apps, leaving dynamic web-based compliance underexplored.

Index Terms: Privacy Compliance, Natural Language Processing, Large Language Models, Retrieval-Augmented Generation, Headless Browser Automation, Cookie Auditing, Telemetry.

1 Introduction

With the rise of data privacy laws worldwide, including the European Union’s General Data Protection Regulation (GDPR) and India’s Digital Personal Data Protection Act (DPDP), digital transparency has shifted from an ethical preference to a legal mandate. Under these frameworks, organizations are legally required to provide users with clear, detailed, and accurate disclosures regarding data collection, processing purposes, and tracking technologies. Furthermore, regulations like the UK’s Privacy and Electronic Communications Regulations (PECR) require explicit user consent before any non-essential tracking technologies (e.g., cookies or device fingerprinting) are initiated.

Despite these legal frameworks, compliance in the real world is highly fragmented. Many organizations use template-based privacy policies that do not accurately represent their actual technical practices. Conversely, dynamic third-party scripts and marketing pixels are often added to websites without the consent or knowledge of the primary site administrator, leading to silent data leaks and compliance violations.

Currently, compliance auditing is performed manually by legal experts and security auditors who inspect website code, examine cookie consent popups, monitor network requests, and read legal documents line by line. This approach is slow, expensive, and unscalable. While automated tools have been

developed to detect trackers or parse privacy policies, they typically operate in silos. Systems either analyze the policy text using Natural Language Processing (NLP) to evaluate readability and completeness, or they inspect network traffic to identify tracking scripts, without cross-referencing the two. The few systems that attempt hybrid auditing are limited to mobile app stores and rely on static program analysis, which is prone to false positives due to unused libraries and cannot address the runtime complexities of web-based cookie consent banners.

To address these limitations, this project proposes an **LLM-Driven Retrieval-Augmented Generation (RAG) Compliance Pipeline**. The pipeline dynamically collects website policy texts and runtime behavioral telemetry (network requests, cookies, console logs, and fingerprinting alerts) and uses an LLM to evaluate them against the ground truth of legal regulations retrieved from a vector database. This hybrid auditing approach bridges the gap between written privacy disclosures ("notice") and actual software execution ("practice"), providing a scalable solution for automated legal auditing.

2 Methodology for Paper Selection

To build a solid academic foundation for this capstone project, a systematic literature search was conducted to identify and analyze ten relevant peer-reviewed papers. The selection methodology was designed to trace the evolution of the field from early statistical NLP models to modern LLMs, and from static program analysis to dynamic network monitoring.

2.1 Search Databases

The following academic search databases were utilized:

- **IEEE Xplore Digital Library** (for security, privacy, and compliance frameworks).
- **ACM Digital Library** (for core natural language processing and web systems research).
- **USENIX Association** (for systems security and empirical privacy auditing papers).
- **Google Scholar** (for broad cross-disciplinary literature search and tracking citations).

2.2 Keywords and Search Queries

The search was performed using combinations of the following keywords:

- *"automated privacy policy compliance"*
- *"privacy policy consistency checking"*
- *"cookie consent auditing GDPR PECR"*
- *"deep learning privacy policy NLP"*
- *"mobile app privacy label inconsistency"*
- *"LLM legal compliance evaluation"*

2.3 Selection Criteria

To ensure the papers selected were directly relevant and of high quality, the following inclusion criteria were applied:

1. The paper must be published in a reputable peer-reviewed conference (e.g., USENIX Security, IEEE S&P, ACM CCS, NDSS, ACL, EMNLP) or journal.

2. The research must present an automated or semi-automated methodology (either code analysis, text classification, or hybrid auditing).
3. The study must address privacy policies, cookie consent compliance, or data privacy regulation enforcement.
4. The selected set of papers must collectively cover both the textual analysis of legal documents and the technical analysis of software behavior.

Using this methodology, ten papers were selected and categorized for in-depth comparative review.

3 Literature Review

The selected literature can be divided into three core categories: (A) NLP and Machine Learning on Privacy Text, (B) Static and Dynamic Software Auditing, and (C) Automated Compliance Verification and Large Language Models.

3.1 NLP and Machine Learning on Privacy Text

Analyzing unstructured legal text is a primary hurdle in automated compliance checking. Wilson et al. [?] established the foundational benchmark for this research by creating the **OPP-115 Dataset**. They manually annotated 115 privacy policies with 23,000 fine-grained data practices across 10 categories, demonstrating that statistical classifiers (such as Support Vector Machines) could automate the categorization of privacy policies. However, their models did not perform deep semantic analysis and were limited to simple keyword associations.

Harkous et al. [?] advanced this field by introducing **Polisis**, a deep learning framework that trained a custom Word2Vec embedding model on over 130,000 privacy policies. Polisis used convolutional neural networks (CNNs) to classify policy segments with 88.4% accuracy and powered **PriBot**, an automated question-answering system. While Polisis enabled scalable text classification, it relied entirely on the written policy text and had no mechanism to verify whether the website actually followed the stated practices.

To improve QA systems, Ravichander et al. [?] created the **PrivacyQA** dataset, comprising 1,750 user questions and over 3,500 expert answers on mobile application policies. They established that fine-tuned BERT models could extract relevant answer spans but noted a 30% F1-score gap between automated models and human legal experts, highlighting the limitations of early transformer architectures in reasoning over complex legal terminology.

3.2 Static and Dynamic Software Auditing

To check whether privacy policies are honest, researchers have developed tools to analyze software behavior directly. Zimmeck et al. [?] proposed a pioneer hybrid system for Android applications. They combined SVM-based privacy policy text classification with static analysis of Android bytecode (tracking API calls and source-to-sink data flows). They audited 17,991 apps and discovered that a significant percentage collected sensitive identifiers (e.g., location or contact lists) without disclosing it in their policy.

Bates et al. [?] introduced **Guardog**, which shifted the focus to "Privacy Nutrition Labels" mandated by app stores. Guardog utilized taint analysis on iOS app binaries to detect data flows and verify if they matched the developer-declared privacy labels. While both Zimmeck et al. and Guardog demonstrated the utility of hybrid auditing, static analysis suffers from high false positive rates due to dead code (code that is present in libraries but never executed) and cannot capture dynamic web behaviors such as cookie setting and JavaScript-based tracking.

Zimmeck et al. later scaled their static compliance check in the **MAPS** project [?], auditing over one million Google Play apps. While MAPS successfully identified widespread omissions and

violations, its architecture was designed specifically for Android compiled binaries. It could not address the dynamic, event-driven architecture of web applications, where tracking behavior changes depending on user interactions with consent banners.

Dynamic auditing of web-based tracking was addressed by Urban et al. [?] and Trevisan et al. [?]. Urban et al. conducted a large-scale dynamic crawl of European websites using headless browser instrumentation to monitor cookie consent banner compliance under the GDPR. They tracked network requests and identified that many sites set tracking cookies *before* the user interacted with the consent banner (pre-consent tracking). Similarly, Trevisan et al. performed a longitudinal study of cookie consent banner compliance, analyzing the presence of cookie tracking over four years. While both studies provided valuable empirical evidence of widespread compliance failures, they focused exclusively on network traffic and did not analyze or cross-reference the text of the websites' written privacy policies.

3.3 Automated Compliance Verification and LLMs

The third wave of research focuses on mapping policy content directly to formal legal frameworks and leveraging generative AI. Zou et al. [?] evaluated the practicality of automated compliance checking under the GDPR. They mapped GDPR Articles 13 and 14 to concrete disclosure requirements and used transformer models to check policies for completeness. They found that while automated completeness checks are possible, natural language ambiguity makes it difficult to verify substantive compliance without deep contextual reasoning.

Finally, Zheng et al. [?] evaluated the performance of Large Language Models (LLMs) as legal compliance evaluators. Using the *LegalBench* dataset, they benchmarked zero-shot and few-shot capabilities of models like GPT-4 and Claude on legal reasoning tasks. They demonstrated that LLMs possess a superior capability to interpret legal clauses and identify violations compared to traditional classifiers. However, their study evaluated LLMs on static, clean text datasets in isolation and did not propose an integration framework to ingest raw software telemetry (such as network HAR logs) alongside policy text.

4 Key Findings

The key findings of the literature review indicate that:

1. Written privacy policies are often incomplete, ambiguous, and fail to disclose active tracking behaviors, especially regarding third-party scripts.
2. Dynamic cookie consent banners on the web frequently fail to block tracking cookies before obtaining user consent, constituting major GDPR/PECR violations.
3. Modern LLMs are capable of reading and interpreting legal documents and classifying compliance violations with high accuracy.

5 Comparative Analysis

As shown in Table 1, the selected papers represent a breadth of methodologies across three distinct research waves. The table provides a detailed comparison of each paper's methodology, dataset, evaluation metrics, strengths, and limitations, enabling a systematic assessment of the current state of the field.

6 Research Gap Identified

Despite the key findings, there is a clear **Research Gap** in the literature:

Most existing systems either analyze the written policy text in isolation (NLP/LLM only) or analyze the software/web behavior in isolation (dynamic crawls/crawlers only). The few hybrid systems that

attempt to match policies to behavior (like MAPS or Zimmeck 2017) are limited to static analysis of compiled mobile app binaries.

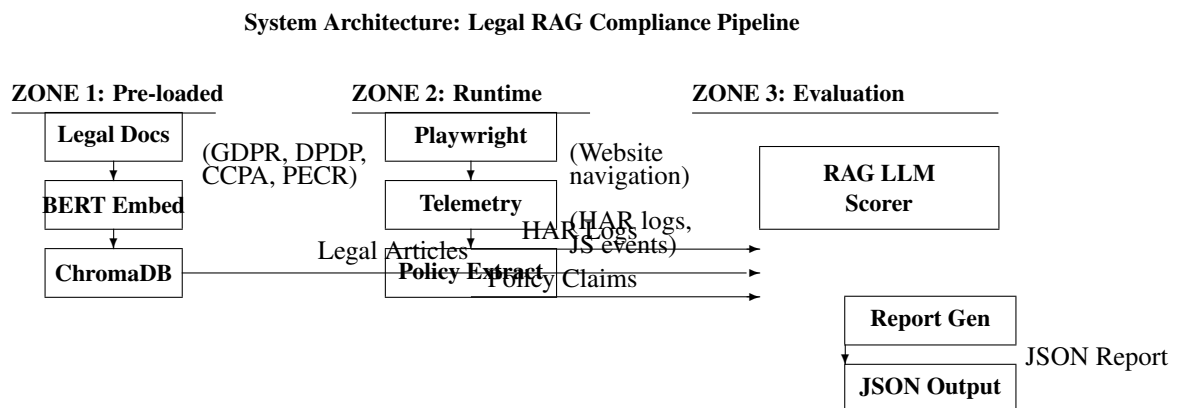
There is currently **no** unified, automated auditing framework that ingests runtime web behavioral evidence (such as network HAR logs and JavaScript event telemetry), retrieves relevant legal standards, and cross-references them in full with scraped policy texts using LLM-driven RAG reasoning to detect real-world non-compliance and contradictions. **This capstone project directly addresses this gap.**

7 Proposed Approach and Methodology

To address the research gap, this project implements a local, privacy-preserving, and automated compliance pipeline that connects legal ground truth, written notice, and software execution.

7.1 Architecture Overview

The system architecture consists of three phases: (1) pre-loaded legal ingestion, (2) runtime telemetry and policy collection, and (3) RAG-based LLM evaluation. Figure 1 shows how data from all three sources converges for compliance scoring.



Data Flows:

- Legal Docs → BERT Embed → ChromaDB (embeds legal articles)
- Playwright → Telemetry → Policy Extract (collects evidence)
- ChromaDB + Telemetry + Policy Extract → RAG Scorer (evaluates compliance)
- RAG Scorer → Report Gen (generates scores, citations, recommendations)

Figure 1: System architecture with three phases: (1) Pre-loaded legal document ingestion into ChromaDB, (2) Runtime telemetry and policy collection, and (3) RAG-based LLM compliance evaluation that integrates legal knowledge, telemetry evidence, and policy claims to produce compliance scores and recommendations.

1. **Legal Document Ingestion (Pre-loaded):** Ground truth compliance regulations (GDPR, DPDP, CCPA, PECR, HIPAA) are loaded once, parsed, and chunked by legal units (Articles and Sections) to preserve semantic coherence. These chunks are embedded using a legal-specific model (*nlpaueb/legal-bert-base-uncased*) and saved in a local, persistent vector database (**ChromaDB**).
2. **Dynamic Telemetry Collection (Runtime):** For any target website, a headless browser agent powered by **Playwright** simulates user navigation. It records all outbound network requests as a HTTP Archive (**HAR**) file and logs JavaScript DOM interactions (like cookie consent banner clicks and canvas fingerprinting) into a *telemetry.json* file.

3. **Policy Extraction (Runtime):** The browser agent identifies, crawls, and extracts the target website's written Privacy Policy and Cookie Policy, converting them into structured Markdown files.
4. **RAG Compliance Evaluation (Runtime):** The orchestrator evaluates compliance across 14 distinct dimensions (including pre-consent tracking, third-party data transfers, and data minimisation). For each dimension:
 - The vector database is queried to retrieve the relevant legal articles.
 - The scraped policy markdown is read to extract the website's claims.
 - The HAR/Telemetry logs are parsed to extract the technical evidence.
 - A local LLM (e.g., Llama 3.3 via Ollama) or a public API is prompted with the combined context (Law + Policy + Behavior) to evaluate compliance, output a score (0–100), identify breaches, cite the exact law article, and recommend specific fixes.
5. **Aggregated Report Generation:** A final compliance report is aggregated, calculating a weighted score based on the severity of the dimensions, and exported as a structured JSON file.

7.2 Key Innovations

- **Notice-to-Practice Verification:** It does not just check if a policy is well-written; it cross-references the text with actual network traffic (HAR logs) to find discrepancies (e.g., policy claims "no marketing cookies," but HAR shows a Facebook tracking pixel set on page load).
- **Legal-BERT Embeddings:** Using a model fine-tuned on legal text ensures that terms like "shall," "must," "controller," and "data subject" are embedded with appropriate legal semantics, improving vector database retrieval.
- **Stealth Instrumentation:** The Playwright client implements anti-fingerprinting evasion scripts to bypass bot detection on complex sites like Facebook and Instagram, enabling the collection of real policies.

8 Datasets

The project utilizes two distinct dataset categories:

1. **Compliance Regulations Dataset (Static):** Text and PDF versions of major privacy laws:
 - General Data Protection Regulation (GDPR) — EU
 - Digital Personal Data Protection Act (DPDP) — India
 - California Consumer Privacy Act (CCPA) — USA
 - Privacy and Electronic Communications Regulations (PECR) — UK
2. **Website Telemetry Dataset (Dynamic):** Collected dynamically per scan. It includes:
 - Scraped Markdown policies from target domains (e.g., www.facebook.com, www.overleaf.com).
 - HAR logs capturing runtime HTTP network requests, headers, and set-cookie actions.
 - Telemetry JSON logs capturing JavaScript execution alerts, canvas fingerprinting calls, and security headers (CSP, HSTS).

9 Project Plan and Milestones

The capstone project is scheduled over a 16-week timeline, divided into five core milestones. Figure 2 provides a visual Gantt chart showing the project schedule and task dependencies.

9.1 Project Schedule Overview

- **Weeks 1–3: Research & Setup (Milestone 1)**
 - Literature review consolidation and setting up the local virtual environment.
 - Downloading and preprocessing the static compliance regulation texts.
- **Weeks 4–6: Legal Ingestion Pipeline (Milestone 2)**
 - Implementing legal document parsing and chunking.
 - Setting up ChromaDB and legal-BERT embeddings.
- **Weeks 7–9: Telemetry & Crawler (Milestone 3)**
 - Developing Playwright-based browser automation.
 - Implementing HAR and telemetry JSON logging.
- **Weeks 10–12: Scorer & RAG Integration (Milestone 4)**
 - Integrating RAG with LLM backend.
 - Developing the 14-dimension compliance scorer.
- **Weeks 13–15: Reporting, Evaluation, & Writing (Milestone 5)**
 - Final testing and integration.
 - Writing project documentation and final report.
- **Week 16: Submission and Presentation**

9.2 Gantt Chart

Phase	Weeks	Duration	Key Deliverables
M1: Research & Setup	1–3	3	Lit. review finalized, environment configured
M2: Legal Ingestion Pipeline	4–6	3	Document parsing, ChromaDB setup, BERT embeddings
M3: Telemetry & Crawler	7–9	3	Playwright automation, HAR collection, policy extraction
M4: Scorer & RAG Integration	10–12	3	RAG retrieval, LLM prompting, compliance scoring
M5: Testing, Eval. & Writing	13–15	3	Integration testing, documentation, final report
Week 16	16	1	Final submission and presentation

Figure 2: 16-week capstone project timeline showing five milestones, duration, and key deliverables.

10 Potential Challenges and Mitigation

Several challenges may arise during the execution of this project:

- **Bot Detection on Complex Sites:** Major platforms (e.g., Meta) use advanced anti-bot systems that block headless Playwright clients.
- *Mitigation:* Implement stealth-routing, user-agent randomization, and load initial policies from known canonical API paths where possible.
- **Context Window Limitations:** Full privacy policies are extremely long (10k+ words). Passing multiple policies and full HAR JSON logs to an LLM might exceed the context window or incur high token costs.

- *Mitigation:* Pre-extract and summarize HAR network traces into structured evidence snippets (e.g., list of set cookies, unique third-party domains) before passing them to the prompt.
- **LLM Hallucinations on Legal Text:** The LLM might cite non-existent articles or misinterpret compliance rules.
- *Mitigation:* Use a strong retriever to inject the exact legal text of the retrieved article into the prompt, forcing the LLM to ground its decisions and quotes in the retrieved text.

11 Use of AI Declaration

In accordance with Capstone Project Guidelines, the use of AI tools in this project is declared as follows:

Large Language Models (including Google Gemini 3.5 and Anthropic Claude 4.6) were used as productivity aids during the development of this proposal and the project code. The use of AI was transparent and intentional, and all AI assistance was disclosed to maintain academic integrity. Specifically, AI tools assisted in:

1. Formatting the LaTeX template structure and drafting academic sections based on manual literature research and systematic review of the ten selected papers.
2. Generating the BibTeX bibliography file based on the metadata and publication details of the selected papers.
3. Designing Python regular expressions for segmenting and parsing legal document structures within the compliance pipeline loader module.
4. Creating the system architecture diagram (TikZ) and Gantt chart (pgfgantt) visualizations for this proposal.

All core technical design decisions, system architecture layouts, algorithm selection, and code debugging were directed, reviewed, and finalized by the author to ensure complete transparency, academic integrity, and code correctness. The author took full responsibility for all architectural choices and implementation details of the compliance system.

Table 1: Comparative Analysis of Foundational Research Papers

Paper	Methodology	Dataset	Eval. Metrics	Strengths	Limitations
Wilson et al. [?]	Manual annotation & SVM classification	OPP-115 (115 privacy policies)	Precision, Recall, F1-score	Established first annotated corpus for privacy NLP.	Small dataset; weak semantic reasoning of SVMs.
Harkous et al. [?]	CNNs & Word2Vec representations	130k privacy policies	Classification accuracy (88.4%)	Scalable categorization; interactive QA assistant.	Purely text-based; cannot verify actual site behavior.
Zimmeck et al. [?]	Static taint analysis & SVM classification	17,991 Android apps	Detection rate of inconsistencies	First hybrid approach matching code to policy.	High false positives from dead code; mobile only.
Ravichander et al. [?]	Fine-tuned BERT QA span extraction	PrivacyQA (1,750 questions)	QA F1-score (baseline gap: 0.3)	Highlighted challenges of legal QA for transformers.	Restricted to short extractive spans; no text generation.
Zimmeck et al. (MAPS) [?]	NLP extraction & static binary analysis	1M+ Google Play apps	Inconsistency rate per app	Massive empirical study showing scale of violations.	Mobile specific; cannot evaluate dynamic web consent.
Bates et al. (Guardog) [?]	Dynamic taint analysis of iOS binaries	Curated iOS apps	Accuracy of label validation	Verifies app store privacy labels against data flows.	Relies on static store metadata; iOS exclusive.
Zou et al. [?]	Transformer classification of GDPR articles	GDPR text & mobile app policies	Policy completeness score	Maps policy clauses directly to specific GDPR sections.	Only checks text completeness, not actual runtime behavior.
Urban et al. [?]	Selenium crawling & traffic classification	100k+ European domains	Cookie counts, pre-consent cookies	Identifies real-world pre-consent cookie violations.	Focuses on network traffic; ignores written policy text.
Trevisan et al. [?]	Dynamic web crawl & heuristic matching	Millions of tracking flows	Tracking cookie percentage	Long-term empirical analysis of GDPR cookie consent.	No NLP/LLM analysis; cannot detect written contradictions.
Zheng et al. (LegalBench) [?]	LLM prompting & zero-shot evaluation	LegalBench dataset	Accuracy on legal reasoning tasks	Proves LLMs can analyze complex legal compliance.	Evaluates isolated text; no integration with web telemetry.